KOMTAS

AI GOVERNANCE READINESS ASSESSMENT

AI Advisory Services

Two services · AI Governance Check, AI Governance Readiness Assessment

1 **The problem and where it sits**
AI is already in use; governance is the control over the layers where AI acts and decides. p. 2 – 3

2 **What is assessed and the two services**
A gate per AI system and ten dimensions; Governance Check and Readiness Assessment. p. 4 – 5

3 **What you get and how it differs**
Result per AI system, governance matrix, closing plan; difference from related work. p. 6 – 7

4 **Next steps**
What is needed from your side and the steps to the start. Appendix from p. 9. p. 8

AI Is Already in Use — Three Questions Without a Clear Answer

KOMTAS

AI already runs in several places: in-house models, vendor products, individual subscriptions. When a board member, an auditor or a customer asks about it, three questions come first.

01 · THE PROBLEM

THREE QUESTIONS THAT COME FIRST

1 — Which AI systems are in use? Inventory

Typical answer today: a list of known projects; AI features in purchased products and individual subscriptions are missing.

2 — Which risk class does each one fall into? Risk class

Typical answer today: classified by technology, or not at all; the use and the decision it feeds are not written down.

3 — Who approved it, and who monitors it? Approval · monitoring

Typical answer today: the technical team knows the system; there is no approval record, no business owner, no switch-off plan.

WHERE AI IS ALREADY IN USE

In-house models and agents
Built by data and AI teams; scoring, chatbots, document AI

AI inside purchased products
AI features switched on in software already in use

Individual subscriptions
Generative AI tools used by staff on their own accounts

Calls embedded in files
AI calls inside spreadsheets, macros and scripts

WHY THE QUESTION COMES UP NOW

Customer questionnaires
EU customers ask about the EU AI Act in supplier assessments.

KVKK guides
Guides on generative AI (November 2025) and agentic AI (March 2026).

EU AI Act in force
Transparency obligations (Art. 50) apply from 2 August 2026.

Audit and the board
Internal audit findings; the board asks which AI is in use.

No AI law does not mean no obligation. An AI system that processes personal data is already within KVKK; sector rules also apply to AI-driven processes.

Where It Sits — Control Over the Layers Where AI Acts

KOMTAS

AI acts and decides in the top two layers. Governance is the control over what runs there; it reaches the two layers below only for the lineage and legal basis of the data these systems use.

01 · WHERE IT SITS

"Which AI systems decide on customers, and who approved them?"

"Each system has an owner, a risk class and an approval record."
built on an inventory, a classification and a control gate per AI system

CONTROL PLANE · WHERE AI ACTS AND DECIDES

Action 360
Intelligent Work Experience

Where AI meets people: chatbots, assistants, generated content, API.

Agent 360
Governed Digital Workforce

Models and agents that score, recommend, decide and act.

LINEAGE AND LEGAL BASIS OF DATA ONLY

Context 360
Enterprise Context

Definitions the AI systems rely on — looked at only for lineage.

Data / Analytic 360
Trusted Data Foundation

Data the AI systems use — checked for sources, personal data and legal basis.

Data sources and legal basis are traced down only for the AI systems in scope

WHERE UNGOVERNED AI SHOWS UP

High-risk use, no approval

A system feeding credit or hiring decisions went live without approval.

Approval

Personal data, no written basis

Personal data is used; the legal basis and DPIA are not written.

Legal basis

A system no one owns

The technical owner is known; no one on the business side owns the outcome.

Business owner

Vendor AI not on any list

An AI feature inside a purchased product; the contract was not reviewed.

Third-party AI

What Is Assessed — a Gate per AI System, Ten Dimensions

KOMTAS

Each AI system in scope is checked against five gate items. In the Readiness Assessment the organisation is also placed on ten dimensions. No single score is calculated.

02 · WHAT IS ASSESSED

FIVE GATE ITEMS · PER AI SYSTEM · BOTH SERVICES

1. **Registered**
   Recorded in an inventory with a named business owner and technical owner
2. **Classified**
   Purpose and affected decision written; risk class with rationale and date
3. **Lawful data use**
   Data sources, personal data and legal basis written; DPIA and contracts checked
4. **Approved with a way back**
   Named approver; human oversight point; rollback and switch-off plan
5. **Monitored**
   A metric with a threshold, an incident path and a periodic review date

STATUS PER ITEM

Met | Partly met | Not met | Not assessed

RESULT PER AI SYSTEM

Governed | Partly governed | Not governed

Governed: all five items met, none “not assessed”. Not governed: not registered, no business owner, or in production without approval. Partly governed: every other case. A system processing personal data without a written legal basis is never Governed.

TEN DIMENSIONS · ORGANISATION LEVEL · ASSESSMENT ONLY

- **D1 AI inventory & registration**
  Completeness, owners, shadow and vendor AI
- **D2 Risk classification & impact**
  Class by use, rationale, impact assessment
- **D3 Policy, standards & approval**
  Written policy, gates by risk class, approvals
- **D4 Roles & accountability**
  Committee, owners, DPO, legal, risk, audit
- **D5 Documentation & transparency**
  System card, limits, user notice
- **D6 Data, legal basis & consent**
  Sources, personal data, copyright, consent
- **D7 Testing, bias & acceptance**
  Evaluation set, criteria written in advance
- **D8 Monitoring & incidents**
  Drift, incident response, rollback, switch-off
- **D9 Third-party & supply chain AI**
  Vendor models, AI in products, contracts
- **D10 Regulatory tracking & audit**
  Rule tracking, capacity to produce evidence

Current and target level per dimension

1 | 2 | 3 | 4 | 5

current

target

Five-level ladder, placed on evidence. No weights and no total score.

The gate decides per system. A gate item that is not met is not offset by high levels in other dimensions; one high-risk system without approval stays a finding.

Two Services — Which One Fits

KOMTAS

AI Governance Check and AI Governance Readiness Assessment. Each can be taken on its own; neither is a mandatory step before the other.

02 · TWO SERVICES

A — AI Governance Check

Gate per declared AI system · documents and interviews

Focus	Whether the declared AI systems pass the five gate items
Scope	5 gate items, per AI system the organisation declares
Result	Indicative result and provisional risk class per system
System access	None
Your team	3 · 4 · 5 days, S · M · L
Evidence	Statement · Document · Observation · Measurement
Weeks	S 1 · M 1.5 · L 2

B — AI Governance Readiness Assessment

Inventory, classification, gates · closing plan and routing

Focus	Which systems are under control, which are not, what closes first
Scope	10 dimensions, gate per system, shadow AI search
Result	Governance matrix, regulatory scope map, closing plan
System access	None required
Your team	6 · 8 · 10 days, S · M · L
Evidence	Statement · Document · Observation · Measurement
Weeks	S 3 · M 3.5 · L 4

WHICH ONE FITS · THE QUESTION ON THE TABLE DECIDES

Is a quick view needed of whether the AI systems already known are under control? → A

Are a full inventory, risk classes and a plan to close the gaps needed? → B

Both? A first: its evidence is reused in B and not billed twice.

What You Get — a Result per AI System

KOMTAS

What each service hands over. The result is given for each AI system, not as one grade for the organisation.

03 · WHAT YOU GET

WHAT IS HANDED OVER

	A	B
Gate per AI system — five items, each with its evidence	✓	✓
Indicative result and provisional risk class, statement-based	✓	–
Key risks and the recommended next step	✓	–
Inventory check, including a shadow and third-party AI search	–	✓
Risk class per system with rationale — indicative	–	✓
Regulatory scope map per system: EU AI Act, KVKK, sector	–	✓
Ten dimensions — current and target level	–	✓
Governance matrix — AI systems × gate items, with priority	–	✓
Closing plan — owner, date, dependency	–	✓
Target role and gate model by risk class; routing	–	✓

RESULT PER AI SYSTEM

Governed
all five items met, none “not assessed”

Partly governed
every other case

Not governed
unregistered, no business owner, or live without approval

Personal data without a written legal basis: never Governed.

EVIDENCE WORDING · REGULATORY ITEMS

- Evidence provided
- Partial evidence
- No evidence produced

No compliance statement; the three states describe evidence, not conformity.

The report opens with a decision, not a maturity level. “N systems are governed; system X (high risk) is in production without approval and must be closed first by …” A Governance Check can be followed by the Readiness Assessment; evidence already collected is reused and not billed twice.

How It Differs From Related Work

KOMTAS

AI governance asks whether the AI systems in use are under control. Related work answers other questions; none of them replaces the other.

03 · HOW IT DIFFERS

AI Governance Readiness · is what already runs under control?

Known, classified, approved and monitored — checked for each AI system. One use of AI is one inventory record and one unit of the result.

AI Readiness

QUESTION

"Can AI work start?"

LOOKS AT

Prerequisites of use cases not yet in production: data access, owner, path to production.

RELATION

For organisations with no AI in production. Its governance dimension routes here; not offered together.

Data governance

QUESTION

"Who owns the data, and is it correct?"

LOOKS AT

Data assets: tables, sources, definitions, data quality, catalogue.

RELATION

Data quality and catalogue stay there. Here, data is checked only for sources and legal basis per AI system.

Model risk management

QUESTION

"How large is the model error?"

LOOKS AT

Statistical accuracy of models such as scorecards and credit models.

RELATION

Model validation stays with the model risk team. Here: whether testing, acceptance and monitoring exist.

Software audit

QUESTION

"Is the code secure and sound?"

LOOKS AT

Security, quality and dependencies of code, including AI-generated code.

RELATION

A separate Komtaş service. Security testing and code review are not part of this assessment.

None of them replaces AI governance.

Even with correct data, which decision a system makes, who approved it and how it is monitored is a separate question. Model risk management looks at model accuracy, not at the legal basis of the use.

WHAT USUALLY FOLLOWS · SEPARATE WORK

- AI inventory set-up and classification
- Control gates, piloted with one high-risk system
- Policy and role model
- ISO/IEC 42001 preparation support

What Is Needed From Your Side — and the Next Steps

KOMTAS

Three roles on your side, two constraints that set the date, and four steps from today to the start of the work.

04 · NEXT STEPS

WHO IS NEEDED ON YOUR SIDE

Sponsor

start and read-out

Sets the decision the work supports and the service to take. Opens access to owners and the AI committee.

System owners

evidence · per system

Business and technical owners describe each AI system, its data and approval; check the findings.

Legal and DPO

throughout

Legal basis, regulatory scope and approvals; confirm the indicative risk classes.

In B, risk, information security, internal audit and procurement join for incidents, vendor contracts and shadow AI records.

TWO THINGS THAT SET THE DATE

AI systems in scope

Each system adds owner interviews and a gate check; in B also classification and a scope map.

High-risk systems first is the main lever

Management calendars

Sponsor, committee and owner interviews depend on calendars, not on team size.

Booked in P0, before interviews start

Neither can be shortened by adding people. Both are asked in the short form, with the list of AI systems in use.

NEXT STEPS

1. **Service walkthrough** — today
   you are here
2. **Service choice and short form** — about one hour
3. **Proposal** — service, band, schedule
4. **Kick-off** — AI system list, interviews, calendar

Start with the systems already running. A Governance Check in one to two weeks, or a Governance Readiness Assessment in three to four when a full inventory, risk classes and a closing plan are needed.

APPENDIX

Method in detail — for reference and questions

1 **Method**
Gate per AI system · Ten dimensions · Maturity ladder · Governance matrix
p. 10 – 13

2 **Risk, inventory and regulation**
Risk classes · Inventory fields · Regulatory scope view: EU AI Act, Türkiye
p. 14 – 17

3 **Team, sizing and limits**
Roles · Duration and sizing · Report, scope and routing · Limits of the assessment
p. 18 – 21

Gate per AI System

KOMTAS

Five items, checked for each AI system in both services. Independent of the ladder: an item that is not met cannot be offset by high levels elsewhere.

	GATE ITEM	WHAT IT MEANS	HOW IT IS VERIFIED	IF NOT MET
1	**Registered**	Recorded in an inventory with a named business owner and a named technical owner	Inventory record, owner assignment	The system cannot be governed; no one answers for its outcome
2	**Classified**	Purpose and affected decision written; risk class assigned with rationale and date	Classification record with rationale	Obligations cannot be set; a high-risk use can go unnoticed
3	**Lawful data use**	Data sources, personal data and legal basis written; DPIA where needed; contract limits checked for vendor AI	Processing record, DPIA, vendor contract	Use of the data may have to stop; data already processed stays a finding
4	**Approved with a way back**	A named approver approved production use; human oversight point, rollback and switch-off plan exist	Approval record, oversight and rollback plan	The system runs on no one's decision and cannot be stopped in a controlled way
5	**Monitored**	At least one metric with a threshold, an incident path and a periodic review date	Monitoring view, incident log, review record	Errors and drift stay unseen until a complaint or an audit finds them

THE GATE IS RUN FOR EACH AI SYSTEM

No single “governed” or “not governed” decision is given for the whole organisation. One system can be under control and another not. Status per item: met, partly met, not met, or not assessed. Result per system: governed, partly governed or not governed.

THE ONLY EVIDENCE THAT A GATE WORKS IS A REJECTED REQUEST

An approval mechanism that has never rejected a request is record keeping, not control. Approval records are therefore read for rejections and conditions as well as approvals; this is usually the first question in an audit.

Ten Assessment Dimensions

KOMTAS

Governance Readiness Assessment (B). Each dimension is placed on the ladder at organisation level. Dimensions are not weighted and no total score is calculated.

	DIMENSION	TOPICS COVERED
D1	**AI inventory and registration**	Whether an inventory exists and how complete it is; shadow and third-party AI coverage; owners per record
D2	**Risk classification and impact assessment**	Classification by use, with rationale and date; re-classification on change; impact assessment
D3	**Policy, standards and approval mechanism**	Written policy, gate set by risk class, approval body, rejected and conditional requests
D4	**Roles and accountability**	AI committee, business and technical owners, DPO, legal, risk, security and internal audit roles per gate
D5	**Documentation and transparency**	Model or system card, documented limits, user notice, marking of generated content
D6	**Data sources, legal basis, copyright and consent**	Data sources per system, personal data, legal basis and DPIA, copyright and consent
D7	**Testing, bias and acceptance criteria**	Evaluation set, acceptance criteria written in advance, bias and error analysis
D8	**Production monitoring and incident management**	Metrics and thresholds, drift, incident response, rollback and switch-off
D9	**Third-party and supply chain AI**	Vendor models, AI inside purchased products, contract terms, provider and user obligations
D10	**Regulatory tracking and audit readiness**	Tracking of EU AI Act, KVKK and sector rules; capacity to produce evidence on request

TWO DIMENSIONS COME FIRST

Inventory and classification: without knowing which systems exist and which class each falls into, the other eight dimensions have nothing to apply to. The gate checks both for each system before the remaining dimensions are placed.

Five-Level Maturity Ladder

KOMTAS

Governance Readiness Assessment (B). Each dimension is placed on this ladder. A level is not claimed — it is shown with evidence; without evidence, one level lower is recorded.

LEVEL 1
Ad hoc

No rules; results depend on people

- No written standard; practices vary by team
- Problems are solved by improvisation
- No measurement; status unknown

Exit: practice is written down

LEVEL 2
Repeatable

Work is done the same way, but not written

- Experienced staff follow the same method
- A newcomer can't repeat the result
- Measurement, if any, is irregular

Exit: rule is documented and owned

LEVEL 3
Defined

Rule is written and applied

- The standard is documented and known
- Deviations are noticed
- Regular measurement, no thresholds

Exit: thresholds set, deviation measured

LEVEL 4
Managed

Measured, thresholds set, deviation visible

- Thresholds defined and monitored
- Deviation detected automatically
- Root cause analysis is done

Exit: correction is automated

LEVEL 5
Optimised

Deviation auto-corrected; continuous improvement

- Correction is largely automated
- Thresholds are updated based on data
- Improvement shown by measurement

THE LADDER SHOWS THE ORGANISATION, THE GATE SHOWS EACH SYSTEM

A high level in policy or roles does not make an individual system governed. The ladder shows how the organisation manages AI; the gate shows, per system, whether it is under control. The Governance Check (A) does not use the ladder; it reports the gate.

TARGET LEVEL IS THE ORGANISATION'S DECISION

Level three in most dimensions is usually enough for an organisation with a few AI systems in production. Higher levels make sense where many high-risk systems run; the target is set together with the organisation, not by the assessment.

Governance Matrix

KOMTAS

The main output of the Governance Readiness Assessment (B): each AI system against the five gate items, with risk class, result and priority. The Governance Check gives the gate columns and an indicative result.

AI SYSTEM · RISK CLASS	REGISTERED	CLASSIFIED	LAWFUL DATA	APPROVED	MONITORED	RESULT	PRIORITY · CLOSE BY

THREE RESULTS

GOVERNED

All five gate items met; none “not assessed”

- Owner, class, legal basis, approval and monitoring are shown
- A next review date is set
- Personal data without a written legal basis: never here

PARTLY GOVERNED

Every case that is neither governed nor not governed

- Includes items partly met, not met or not assessed
- Each open item gets an owner and a date
- Priority follows the risk class

NOT GOVERNED

Not registered, no business owner, or in production without approval

- A high-risk system in this group is closed first
- Options: close the gap, restrict use or switch off
- The choice is the organisation's decision

WHY NO SINGLE GOVERNANCE GRADE IS GIVEN

“The organisation's AI governance maturity is 2.8 out of 5” serves no decision. One high-risk system in production without approval matters more than any average. The result is per system; dimension levels explain the reasons behind it, they are not the decision itself.

Risk Classification

KOMTAS

Obligations arise from the purpose of use and the decision affected, not from the technology

UNACCEPTABLE
Prohibited

EXAMPLE AREAS

- Certain social scoring practices
- Manipulative techniques exploiting vulnerabilities
- Non-consensual explicit image generation

The system cannot be used; if it exists, it is switched off

HIGH RISK
Strict obligations

EXAMPLE AREAS

- Employment and recruitment
- Credit and access to finance
- Education and exam assessment
- Critical infrastructure

Risk management, data governance, documentation, human oversight, conformity assessment

LIMITED RISK
Transparency

EXAMPLE AREAS

- Chatbots and customer interaction
- Generative content and synthetic media
- Emotion recognition notice

Informing the user and marking the content

MINIMAL RISK
Free use

EXAMPLE AREAS

- Internal productivity tools
- Recommendation and ranking
- Document summarisation

No specific obligation; internal control is the organisation's own decision

GENERAL-PURPOSE AI MODELS (GPAI) ARE UNDER A SEPARATE REGIME · **The obligations of the model provider and of the organisation using the model are not the same**

SAME MODEL, DIFFERENT CLASS

A language model is minimal risk in internal document summarisation and can be high risk when the same model is used to assess job applicants. Classification is therefore done per use, not per model, and each inventory record represents one use.

CLASSIFICATION IS NOT A ONE-OFF TASK

When the purpose of use changes, the class changes. In the assessment each class is given with its rationale and stays indicative until the organisation's legal or compliance unit confirms it.

AI Inventory — the First Condition of Governance

KOMTAS

A system that is not known cannot be governed. An inventory is not a list but a record in which every row points to a person responsible.

FIELD	CONTENT
Identity	System name, short description, internal reference number
Purpose and decision	What it does, which decision it feeds, whether the decision is final or a recommendation
Ownership	Business owner, technical owner, using unit
Lifecycle status	Idea · development · pilot · production · retired
Model and provider	Model type, built in-house or procured, provider and version
Data	Data sources used; whether personal data or special category personal data is included
Legal basis	Processing condition, notice status, need for and status of a DPIA
Risk class	Class, rationale for the class, date of the last assessment
Human oversight	Who can intervene at which point; how the system is switched off
Monitoring	Which metric is monitored, threshold, last review and its result
Dependency	Which process and which other system depend on it; what happens if it stops

THE HARDEST PART OF THE INVENTORY IS SHADOW AI

Use outside the inventory is the hardest to see: individual subscriptions, calls embedded in spreadsheets, AI components inside vendor products. An inventory is not complete until these are searched for. In the Readiness Assessment the search is limited and evidence-based.

PROCURED AI IS ALSO IN THE INVENTORY

An AI component that comes inside a purchased product is still the organisation's responsibility. The provider's obligations do not remove the user's; which party commits to what in the contract should be recorded in the inventory.

Regulatory Scope View — EU AI Act Timeline

KOMTAS

As of October 2026, to be reconfirmed before use. The timeline changed in 2026 with the Digital Omnibus: high-risk obligations were postponed, transparency was not.

DATE	WHAT APPLIES	SCOPE
1 Aug 2024	**Regulation entered into force**	Phased application started
2 Feb 2025	**Prohibited practices and AI literacy**	Art. 5 prohibitions and Art. 4 literacy obligation
2 Aug 2025	**GPAI, governance and penalties**	General-purpose model obligations; AI Office and enforcement framework
2 Aug 2026	**Art. 50 transparency obligations**	Disclosure of synthetic content and informing users in interaction
2 Dec 2026	**End of transition for existing systems**	Machine-readable marking under Art. 50(2) for generative systems placed before 2 Aug 2026
2 Dec 2027	**Annex III high-risk systems**	Main obligations of stand-alone high-risk systems — postponed by the Omnibus
2 Aug 2028	**Annex I embedded high-risk systems**	Systems covered by product legislation
2 Aug 2030	**Public authority systems**	High-risk systems used by public bodies

WHAT THE DIGITAL OMNIBUS CHANGED

- Annex III high risk: 2 Aug 2026 → 2 Dec 2027
- Annex I embedded systems: 2 Aug 2027 → 2 Aug 2028
- Art. 50 transparency not postponed — applies from 2 Aug 2026

ADMINISTRATIVE FINES

- Prohibited practices: EUR 35 million or 7% of global turnover
- Other breaches: EUR 15 million or 3%
- Misleading information to authorities: EUR 7.5 million or 1%

WHY IT CONCERNS AN ORGANISATION IN TÜRKİYE

The Regulation can cover not only providers established in the EU but also systems whose output is used in the EU, and EU customers ask about it in supplier assessments. In the scope map, EU exposure is recorded for each AI system, not for the organisation as a whole.

Regulatory Scope View — Türkiye

KOMTAS

As of October 2026 there is no separate AI law in force; the subject is covered by existing legislation and sector regulation. To be reconfirmed before use.

IN PLACE TODAY

- No AI-specific law in force
- KVKK — Guide on Generative AI and Personal Data Protection (November 2025)
- KVKK — Guide on Agentic AI (12 March 2026)
- The guides are not binding; they show the Authority's assessment approach
- National AI Strategy 2021 – 2025 — policy framework, not binding
- Covered indirectly by KVKK (Law No. 6698), TCK, FSEK, consumer and competition law

ON THE WAY

- TBMM AI Research Commission report — March 2026, order no. 260
- The report proposes a framework law
- It proposes setting up a national AI authority
- It proposes regulatory sandboxes
- It proposes a data mining exception in FSEK
- It proposes ratifying the Council of Europe Framework Convention on AI

REGULATOR	AREA	TYPICAL AI USE
KVKK	Personal data processing, legal basis, notice, DPIA	Any system that processes personal data
BDDK	Information systems and electronic banking regulations	Credit scoring, fraud detection, operational automation
SPK	Capital market activities	Robo-advice, algorithmic trading, portfolio management
Ministry of Health	Medical device legislation and certification	Diagnostic support and image analysis software
TCMB · BTK · RTUK	Payment services, electronic communications, broadcasting	Payment risk engines, subscriber analytics, synthetic media

NO LAW DOES NOT MEAN NO OBLIGATION

An AI system that processes personal data is already within KVKK; the sector regulator's existing information systems and risk rules also apply to AI-driven processes. “No law yet” does not defer existing obligations.

HOW THE SCOPE MAP USES THIS

For each AI system: EU AI Act exposure, KVKK and the applicable sector regulator, with evidence stated as provided, partial or not produced.

Competencies and Roles

KOMTAS

Which role is active in which phase. The Governance Check runs with the lead, the AI governance and AI / ML consultants. P0 scope · P1 evidence · P2 gate · P3 closing plan (B) · P4 read-out.

ROLE	DUTIES	PARTY	ACTIVE PHASES
Assessment Lead	Method, scope, gate per AI system and report	**Komtaş**	P0 – P4
AI Governance Consultant	Inventory, classification, gates, policy; KVKK and legal basis	**Komtaş**	P0 – P3
AI / ML Consultant	Documentation, testing and monitoring of AI systems	**Komtaş**	P1 – P2
Regulation and Risk Consultant	Regulatory scope map, risk classes, sector rules; no legal opinions	**Komtaş**	P1 – P3 · B only
Data Architect	Data sources, lineage, data side of the legal basis	**Komtaş**	P1 – P2 · B only
Third-Party and Platform Specialist	Shadow AI and third-party AI search, vendor contracts	**Komtaş**	P1 – P2 · B only
Organisation Consultant	Roles, AI committee, decision rights	**Komtaş**	P1 – P3 · B only
Project sponsor	Decision-making, opening access and the interview calendar	**Customer**	P0, phase transitions
AI Committee / Senior Management	Policy, risk appetite, approval of high-risk systems	**Customer**	P1, P4
Business and Technical Owners	Purpose, data, approval, testing and monitoring of each system	**Customer**	P0 – P2
Legal, Compliance and DPO	Legal basis, regulatory obligations, confirmation of risk classes	**Customer**	P1 – P3
Risk, Security and Internal Audit	Thresholds, incidents, attack surface, control testing	**Customer**	P1
Procurement and IT	Vendor contracts; licence, expense and usage records for shadow AI	**Customer**	P1

NO ASSESSMENT WITHOUT ACCESS TO SYSTEM OWNERS

If the business owners of the AI systems cannot be interviewed, the first gate item cannot be verified and dimension D4 falls back to statements.
The business owner is the role most often missing; when that is the case, it is recorded as a finding.

Duration and Sizing by Service

KOMTAS

Indicative band values. The band is set from the short form; dates are fixed at kick-off, once the AI system list and interview calendar are known.

SERVICE	SMALL	MEDIUM	LARGE
A · AI Governance Check 5 gate items · per declared AI system	1 week · 3 days	1.5 weeks · 4 days	2 weeks · 5 days
B · AI Governance Readiness Assessment 10 dimensions · gate · shadow AI search	3 weeks · 6 days	3.5 weeks · 8 days	4 weeks · 10 days

Cell format: duration · time needed from your team (days). Your team's time grows with the number of AI systems. Commercial terms are set out in the proposal.

SIZING DRIVERS

DRIVER	SMALL	MEDIUM	LARGE	USED IN
AI systems in scope	≤ 5	6 – 20	> 20	A · B
Business units using AI	1 – 2	3 – 6	> 6	A · B
People to interview	≤ 10	10 – 25	> 25	A · B
Third-party / vendor AI components	≤ 3	4 – 10	> 10	A · B
Applicable regulators	1	2 – 3	> 3	A · B
Legal entities or locations	1	2 – 3	> 3	A · B
Degree of regulation	Low	Medium	High	B
Documentation maturity	Written	Partial	None	B
Access to senior management calendar	Easy	Medium	Hard	B
Previous assessment or audit	Yes	Partial	No	B

BAND RULE · the highest band that at least three drivers fall into. One large driver alone does not set the band.
With more than 20 AI systems in the Governance Check, the gate is applied to high-risk and production systems first and to a sample of the rest.

Report, Scope and Routing

KOMTAS

The report does not give a maturity grade; it gives a result per AI system and a plan to close the gaps

WHAT THE REPORT CONTAINS

- Governance matrix and the result per AI system
- Risk class per system with rationale — indicative
- Regulatory scope map with three-state evidence wording
- Level per dimension and the evidence behind it
- Closing plan, target role and gate model, routing

WHAT THE REPORT DOES NOT CONTAIN

- Legal opinion or compliance statement
- Inventory set-up, policy writing, committee set-up
- Model validation or data quality measurement
- Security testing or code audit
- A single grade or weighted score

ROUTING

- No AI in production — AI Readiness Assessment
- Data quality and catalogue — data governance work
- Code security and quality — software audit
- Inventory and gates — set-up as follow-on work
- Routing follows from a finding; it is not a sales proposal

THE REPORT OPENS WITH A DECISION

Not with “your maturity is at level N”, but with “N systems are governed; system X (high risk) is in production without approval and must be closed first by …”.
If the executive summary cannot be reduced to such sentences, the assessment has not answered its question.

REFERENCE FRAMEWORKS ARE USED AS A METHOD, NOT A CERTIFICATION

Findings follow the EU AI Act risk logic and are mapped to ISO/IEC 42001 and NIST AI RMF headings where useful.
This does not certify the organisation and is not a conformity assessment.

THE ASSESSMENT MEASURES, IT DOES NOT BUILD

Setting up the inventory, writing the policy and running the gates are separate pieces of work.
The evidence and findings of the assessment are their starting point.

Limits of the Assessment

KOMTAS

What this work does not do is stated explicitly within the report

Not legal advice

The work gives findings and evidence. Obligations specific to the organisation are assessed with its legal and compliance units.

No compliance statement

Evidence is stated in three states: provided, partial, not produced. Conformity can only be stated by authorised bodies.

Risk classes are indicative

Each class is given with its rationale and becomes final once the organisation's legal or compliance unit confirms it.

Nothing is built

Inventory set-up, policy writing, committee set-up, gate implementation and tooling are separate follow-on work.

No model validation, no data quality

Statistical model accuracy stays with model risk teams; data quality and catalogue stay with data governance.

No security testing or code audit

Security and quality of code, including AI-generated code, are the subject of a separate software audit service.

REGULATORY FACTS ARE RECONFIRMED BEFORE USE

Regulatory content is compiled as of October 2026. The EU timeline changed once in 2026 and a framework law process continues in Türkiye; dates and references are reconfirmed when the proposal is prepared. Only the official texts are binding.

THE DECISION IS THE ORGANISATION'S

The report shows which systems are under control and what should close first. Whether to keep, restrict or switch off a system is the organisation's decision; the matrix does not replace it.

NOT OFFERED TOGETHER WITH AI READINESS

An organisation is either at the point of starting AI or of governing what already runs; which service fits is settled in the first meeting.